

Information Security Management System Shameless Consulting Ltd.

MT Consulting

Author: Mark To

May 12, 2025

For internal use only

Version	Date	Author	Summary of Change
1.0	03/01/2025	Mark To	Added and updated sections 1-4
1.1	04/18/2025	Mark To	Added and updated sections 5-7
1.2	05/04/2025	Mark To	Added and updated sections 8, Data Classification and Handling Policy, Acceptable Use Policy, Acceptable Use Procedure
1.3	05/10/2025	Mark To	Added Executive Summary
1.4	05/12/2025	Mark To	Edited, updated sections 6, 7, Data Classification and Handling Policy

Executive Summary.....	5
1. Introduction.....	6
2. Obligation.....	6
3. Scope.....	8
3.1 Scope Statement.....	9
4. Legal Considerations.....	10
5. Asset Management.....	11
5.1. Asset identification process and definition.....	11
5.2. Categorization.....	11
5.3. Classification Scheme.....	12
5.4. Identification, Storing, and Tracking.....	13
5.5. Process Flow Chart.....	14
5.6. Recorded Asset Information Table.....	14
5.7. Asset Criticality and Responsibility.....	14
6. Risk Management.....	16
6.1. Risk Assessment Methodology.....	17
6.1.1. NIST 800-30 as an Alternative.....	18
6.1.2. OCTAVE as an Alternative.....	18
6.1.3. ISO 27001: Compliance driven, Structured Approach.....	18
6.1.4. Justification for ISO 27001: Why it is the best fit for Shameless.....	19
6.1.5. Implementing ISO 27001 as a Long-term Strategy.....	19
6.1.6. Relation to NIST Cybersecurity Framework.....	19
6.2. Risk Factors.....	20
6.2.1. Internal factors.....	20
6.2.2. External Factors.....	20
6.2.3. Quantitative vs. Qualitative Risk Analysis.....	21
6.2.4. Impact of Risks.....	22
6.2.5. Legal Requirements and Consequences of Non-compliance.....	22
6.3. Control Strategies.....	23
6.3.1. Transfer.....	23
6.3.2. Defense.....	23
6.3.3. Mitigation.....	23
6.3.4. Acceptance.....	24
6.3.5. Termination.....	24
6.4. Residual Risk.....	24
6.5. Introduction to Risk Register (Risk Identification and Description).....	25
6.5.1. Asset Identification.....	25
6.5.2. Threat and Vulnerability Identification.....	25
6.5.3. Threat Exploitation Likelihood.....	26
6.5.4. Threat Impact Classification.....	26

6.5.5. Risk Treatment.....	27
6.6. Threats and Vulnerabilities: Confidentiality, Integrity, and Availability.....	28
6.7. ISO 27001 Clauses.....	28
7. Incident Response.....	29
7.1. Framework Selection: NIST 800-61.....	30
7.1.1. Why NIST 800-61?.....	30
7.1.2. Framework Comparison (NIST 800-61 vs. SANS Incident Handler's Handbook).....	31
7.1.3. Addressing NIST Shortcomings.....	32
7.2. Defining and Classifying Security Incidents.....	32
7.3. Detection and Reporting Tools.....	32
7.3.1. Detection Tools.....	32
7.3.2. Reporting Mechanisms.....	33
7.4. Incident Response Metrics.....	34
7.4.1. Key Performance Indicators (KPIs).....	34
7.5. Documentation and Response Roles.....	34
7.5.1. Documentation Tools.....	35
7.5.2. Contingency Plan Management Team (CPMT).....	35
7.5.3. Flow of Decision-Making.....	35
7.6. Incident Response Walkthrough: Brute-Force & Phishing Attack.....	36
7.6.1. Case Summary.....	36
7.6.2. Using NIST 800-61 Methodology.....	36
7.6.2.1. Preparation.....	36
7.6.2.2. Detection and Analysis.....	37
7.6.2.3. Containment, Eradication, and Recovery.....	37
7.6.2.4. Resolution Criteria.....	38
7.6.2.5. Post-incident Activity.....	38
7.6.2.6. Incident Response Flow Diagram.....	38
8. Policies.....	38
8.1. Policy Selection.....	39
Data Classification and Handling Policy.....	41
Acceptable Use Policy.....	45
Acceptable Use Procedure.....	49
References.....	55

Executive Summary

This Information Security Management System (ISMS) report has been developed to provide Shameless Consulting Ltd. with a strategic framework for managing and securing its information assets. As a growing multinational insurance provider now operating in cybersecurity product sales and high-risk client data processing, Shameless faces considerable information security threats that demand a mature, enforceable, and organization-wide security approach. This ISMS initiative is a foundational investment in the company's resilience, operational continuity, and long-term brand trust. It has been designed in direct response to a series of critical weaknesses, breaches, and legal exposures uncovered in the past year, many of which have resulted in lost data, financial damage, regulatory violations, and reputational harm. The ISMS, in combination with supporting policy frameworks and procedures, will allow Shameless to implement a risk-informed approach that enhances security while enabling continued innovation and business growth.

Our risk register and interviews with Shameless staff have identified a range of vulnerabilities, including **malware infiltration** via phishing and vulnerable infrastructure, **unpatched systems**, **weak physical and network security controls**, **lack of formal cybersecurity training** and device management, and **GDPR/CPRA non-compliance risks** due to improper data classification and reporting. These risks directly compromise business continuity, legal compliance, client data integrity, and ultimately, the company's financial standing.

Top 5 Risks and Recommendations

Risk	Recommendation
Phishing and Social Engineering Attacks: Multiple successful incidents, including credential harvesting, affecting senior staff	Implement company-wide cybersecurity training (via Learning Management System (LMS) such as KnowBe4), quarterly phishing simulations, and enforce MFA and password standards company-wide
Lack of Centralized Patch and Vulnerability Management: Multiple unpatched Common Vulnerabilities and Exposures (CVEs) exploited (e.g., CVE-2024-20359, Zerologon)	Deploy an automated Vulnerability Management Dashboard; prioritize systems with critical CVEs
Device Theft and Lack of Encryption: Unencrypted mobile/laptop device loss containing sensitive PII	Mandate full disk encryption security software (BitLocker/FileVault), implement mobile device management (e.g., Intune), enforce endpoint monitoring via CrowdStrike Falcon
Poor Backup, Redundancy, and Disaster Recovery: Failed restore efforts after Bridlington flood	Establish a tested, cloud-synced backup and Disaster Recovery plan with offsite replication; replace legacy

	tapes with encrypted cloud storage and monthly restore simulations
Data Breaches and GDPR/CPRA Violations: 1,000-client data breach unreported	Enforce a Data Classification and Handling Policy, implement breach reporting workflows, ensure 72-hour breach reporting per GDPR

Legal Obligations

Shameless must comply with several legal and industry standards, including:

- GDPR (EU) – Requires breach reporting within 72 hours, proper PII handling, and DPO oversight. Non-compliance may lead to fines up to €20 million or 4% of global turnover, whichever is higher.
- CPRA (California) – Imposes transparency, deletion rights, and data breach penalties, with fines up to \$7,500 per intentional violation.
- HIPAA (U.S. Health Data) – Applicable to any health-related customer information, with potential fines ranging from \$100 to \$50,000 per violation.
- PCI-DSS – Enforced for secure handling of payment data; violations may result in credit card company sanctions or revocation of processing rights.

Failure to meet these legal obligations exposes Shameless to multimillion-dollar penalties, legal liability, client lawsuits, and reputational decay.

1. Introduction

Thank you for trusting us. At MT Consulting, we deliver high-end security and risk management solutions to businesses worldwide. This Information Security Management System (ISMS) has been developed to provide Shameless Consulting Ltd. with a comprehensive, risk-informed framework that protects your most critical assets, aligns with international standards, and ensures your readiness for continued growth in a highly regulated and increasingly digital marketplace.

2. Obligation

Shameless Insurance Ltd. is a multinational insurance provider with operations spanning across the UK, USA, and India. Its services in cybersecurity insurance makes information security a critical aspect of its business model. This Information Security Management System (ISMS) is designed to enhance Shameless' security maturity. It covers a structured framework that integrates policies, procedures, security controls, and methodologies intended to strengthen the company's security while ensuring regulatory compliance and business continuity. Given the

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

increasing number of cyber threats, including malware attacks, phishing scams, data breaches, and unpatched vulnerabilities, Shameless must implement a robust ISMS to protect its assets and reputation.

The purpose of an ISMS is to establish a systematic approach to safeguarding Shameless' sensitive information and assets through risk management strategies and incident response protocols. This includes data security, network infrastructure, personnel, and hardware. It ensures compliance with regulatory standards such as GDPR, CPRA, PCI-DSS, and HIPAA, thus reducing the risk of legal penalties and reputational damage. By addressing vulnerabilities, strengthening network security, and implementing security awareness training, the ISMS mitigates cyber risks. Additionally, it enhances business resilience by ensuring that critical systems and data remain available and secure in the face of potential threats. The ISMS establishes structured processes for incident response and recovery, reducing downtime and improving Shameless' ability to handle security breaches effectively.

Moreover, an ISMS fosters a culture conscious of security within the organization. By integrating cybersecurity best practices into daily operations, employees become more vigilant about potential risks. This approach not only secures the company's digital infrastructure, but also empowers staff to recognize and prevent cyber incidents proactively.

Implementing an ISMS brings significant advantages for Shameless Ltd, its clients, as well as key stakeholders. Senior management will benefit by gaining insights into risk assessments, compliance strategies, and financial risks, which allow for informed financial and security decision making. The information technology and security teams will have access to clearly defined security policies, regular vulnerability assessments, and compliance guidelines that enhance operational security. Operational staff will receive cybersecurity awareness training, helping them identify phishing attempts, social engineering tactics, and best practices for securing sensitive data. Clients and stakeholders will continue to be invested in the company, as strong security measures will protect their confidential information and reinforce trust in Shameless' services.

A comprehensive ISMS not only benefits the organization internally, but also enhances Shameless' reputation in the market. As data privacy concerns continue to rise, customers and partners are increasingly prioritizing businesses that demonstrate strong security practices. By achieving compliance with global regulatory standards and implementing robust security controls, Shameless can position itself as a trusted and responsible service provider, attracting more clients and business opportunities.

The ISMS will provide protection against multiple cybersecurity threats. It will mitigate phishing and social engineering attacks through security awareness training. It will also defend against malware and ransomware by deploying anti-malware solutions. Implementing strong encryption, access controls, and data loss prevention (DLP) tools, the ISMS will reduce the risk of data

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

breaches. Furthermore, ensuring compliance with GDPR, CPRA, PCI-DSS, and HIPAA will prevent regulatory fines, while business continuity planning (BCP) and disaster recovery (DR) measures will help Shameless maintain operational resilience.

Additionally, the ISMS will address the growing risk of zero-day vulnerabilities and advanced persistent threats (APTs), which target organizations over extended periods of time. Incorporating continuous monitoring, threat intelligence, and regular penetration tests will ensure that Shameless can stay ahead of emerging threats and respond to potential attacks before they cause significant harm.

The implementation of Shameless Insurance Ltd's ISMS will incorporate the NIST Cybersecurity Framework (CSF) to establish a standardized, risk-based approach to cybersecurity management. The CSF, developed by the National Institute of Standards and Technology (NIST), provides a structured methodology to identify, protect, detect, respond to, and recover from cybersecurity threats. Integrating the CSF into the ISMS will strengthen Shameless' risk management processes, ensuring compliance with regulatory standards while improving its security maturity. This framework also facilitates a continuous improvement cycle, ensuring that Shameless adapts to evolving cyber risks and regulatory changes. Additionally, incorporating the CSF will enhance stakeholder confidence by demonstrating a commitment to comprehensive cybersecurity governance.

3. Scope

The scope of the ISMS requires a strategic approach that considers Shameless' business model, operational risks, and previous security incidents. Given that the company has experienced data breaches, phishing attacks, and unpatched vulnerabilities, a targeted implementation is required to prioritize the most vulnerable areas first.

The most effective approach for implementing the ISMS at Shameless Insurance Ltd. is to apply it across the entire organization. By ensuring that all departments, employees, and systems are included in the ISMS, the company can create a unified and consistent security framework that minimizes vulnerabilities across all areas of operation. Given that Shameless operates in multiple jurisdictions and handles sensitive customer and employee data, restricting the ISMS to only key departments would leave significant gaps in security coverage.

A company-wide ISMS ensures that security policies, risk management strategies, and compliance measures are standard across all levels of the organization. This holistic approach enhances visibility into potential threats and vulnerabilities, allowing for proactive monitoring, incident response, and continuous improvement.

An ISMS that covers the entire organization provides the most robust defense against regulatory penalties. With multiple laws such as the GDPR, CPRA, PCI-DSS, and HIPAA imposing strict requirements for data protection, an organization-wide approach mitigates the risk of non-compliance and ensures that sensitive data is handled securely at all levels.

While the costs and management complexity of an organization-wide ISMS are higher compared to a phased or department-specific implementation, the long-term benefits far outweigh the initial investment. By adopting a centralized security governance model, Shameless can optimize its security resources, prevent regulatory fines, and enhance its reputation as a trustworthy and secure business.

3.1 Scope Statement

This ISMS will apply to all departments, employees, systems, and processes within Shameless Insurance Ltd., ensuring a unified, organization-wide security framework. Given the company's exposure to regulatory requirements such as the GDPR, CPRA, PCI-DSS, and HIPAA, a limited ISMS scope could leave vulnerabilities unaddressed and increase the risk of compliance failures. Additionally, past security incidents have demonstrated that threats are not confined to a single department. A holistic, organization-wide approach is essential for safeguarding sensitive information, ensuring compliance, and mitigating security threats effectively.

The scope of the ISMS will be aligned with the NIST Cybersecurity Framework (CSF) to ensure a comprehensive, organization-wide approach to managing cybersecurity risks. This ensures that every function is aligned with the best practices for identifying, protecting, detecting, responding to, and recovering from cybersecurity threats. The adoption of a universal ISMS strengthens visibility into potential security gaps, enabling proactive monitoring and incident response.

3.2 Departments Covered

The ISMS will encompass all corporate functions and personnel.

- 3.2.1 Network Manager: Overseeing the integrity and security of Shameless' network infrastructure, ensuring encryption, firewalls, and intrusion detection systems are properly configured and maintained.
- 3.2.2 Data Protection Officer: Overseeing compliance with data protection regulations, managing data privacy policies, conducting risk assessments, and ensuring GDPR, CPRA, PCI-DSS, and HIPAA compliance across all organizational processes.
- 3.2.3 Help Desk and Operations Operative: Managing incident tracking systems, customer support communications, and access controls while enforcing security protocols in day-to-day operations.

- 3.2.4 Senior Talent Advisor (HR): Securing employee records and recruitment platforms that contain sensitive information, ensuring compliance with employment data protection laws.
- 3.2.5 Cybersecurity Analyst: Conducting vulnerability assessments, monitoring threats, conducting cyber awareness training, and ensuring the implementation of security best practices across Shameless' digital assets and operations.

4. Legal Considerations

Shameless Insurance Ltd. operates in various countries, which means compliance with various legal regulatory requirements is essential to maintaining secure business operations. The CSF's identify, protect, detect, respond, and recover functions will be integrated into Shameless' legal compliance strategy to systematically address security risks, ensure timely breach reporting, and reduce the likelihood of regulatory penalties. This risk-based approach ensures that security controls are mapped to the GDPR, CPRA, PCI-DSS, and HIPAA requirements.

- General Data Protection Regulation (GDPR)
 - Requires organizations to protect personal data and report breaches within 72 hours.
 - Right to know, the Right to delete, the Right to opt-out, and the Right to Non-discrimination. Right to Rectification and Limit Use and Disclosure of Sensitive Personal Information.
 - Non-compliance can result in fines of up to €20 million or 4% of annual global revenue, whichever is higher.
- California Privacy Rights Act (CPRA)
 - Applies to organizations handling personal data of California residents.
 - Non-compliance can lead to fines of \$2,500 per unintentional violation and \$7,500 per intentional violation.
- 2.3 Payment Card Industry Data Security Standard (PCI-DSS)
 - Applicable to businesses that process credit card transactions.
 - Requires encryption, strong authentication, and regular vulnerability assessments to protect payment information.
 - Non-compliance can lead to fines ranging from \$5,000 to \$500,000 per incident.
- 2.4 Health Insurance Portability and Accountability Act (HIPAA)
 - Industry standards that are mandated for any organization that handles credit, debit, and specialty payment cards.
 - Non-compliance can result in fines ranging from \$100 to \$1.5 million per violation.

5. Asset Management

Asset management is a function within the ISMS of Shameless Consulting Ltd. that ensures information assets are properly identified, categorized, protected, and managed throughout their lifecycle. The goal is to minimize security risks, prevent unauthorized access, and ensure compliance with industry regulations such as GDPR, CPRA, PCI-DSS, and HIPAA.

Asset management is crucial for Shameless due to recent security incidents, data breaches, hardware theft, malware attacks, and compliance failures. Implementing a structured asset management process will strengthen Shameless' security posture while mitigating financial and reputational risks.

5.1. Asset identification process and definition

According to NIST SP 800 160v2r1, an asset is anything of value to stakeholders. An asset can be both tangible (physical devices, servers, or individuals with roles within an organization) and intangible (such as databases, customer information, software applications, image, or reputation).

At Shameless Consulting Ltd., asset identification is conducted through a structured, repeatable process that aligns with both NIST and ISO standards. The goal is to ensure that every asset is accounted for, evaluated, and protected according to its value and associated risk exposure. The process begins with a comprehensive asset discovery audit, involving collaboration across departments to gather data on all hardware, software, data repositories, personnel roles, and third-party dependencies.

Each discovered asset is then documented and entered into a centralized Asset Register, where it is assigned a unique identifier and categorized. This categorization facilitates visibility and also aligns assets with their respective confidentiality, integrity, and availability requirements. Attributes such as asset owner, data sensitivity, lifecycle stage, physical location, and support contracts are also captured.

Once inventoried, assets are further classified based on criticality. This enables targeted security controls, efficient resource allocation, and effective risk assessment, ensuring that Shameless can prioritize its protection efforts and reduce the likelihood of unmanaged assets introducing vulnerabilities.

5.2. Categorization

The purpose of this section is to manage the information of assets by categorizing them into different types. Categorizing assets helps establish security priorities and streamline risk management while allowing for easy access and accuracy of asset information. We recommend

Shameless Ltd. to categorize the asset information into the following categories: People, Software, Hardware, Policies and Procedures, Networking Components, and Data.

Effective categorization enhances the efficiency of incidence responses, as high-risk assets can be quickly identified and prioritized in the case of a security breach. Resources can be allocated to security solutions for critical assets while reducing any potential financial inefficiencies. Categorization also simplifies audit processes, making it easier to track compliance and assess vulnerabilities across different asset groups.

The Asset Register includes some assets and their details from each office location of Shameless. You may access the Asset Register through this link: [Asset Register](#).

People	Employees and their skills are considered an asset to the company and their attributes should be accounted for accordingly.	Ex. Head of IT; record staff ID, position name, security clearance level, and special skills
Software	Software requires regular security updates and vulnerability assessments.	Ex. Payroll; record asset ID, manufacture name, version, cost
Hardware	Hardware requires frequent maintenance and service to ensure functionality.	Ex. Company desktop; record asset tag, name, manufacturer, model, IP/MAC addresses
Policies and procedures	Every company has a set of policies and procedures to abide by, and it's important to account for document attributes.	Ex. Password policy; record document number, name, owner, description, and purpose
Networking components	Firewalls, VPNs, access points, and switches support secure data transmission.	Ex. Router; record asset tag, firewalls, VPNs, model, IP/MAC addresses
Data	Data is collected throughout the organization from employee records to customer purchases and transactions.	Ex. Customer database; record size, owner, online status, location, backup

5.3. Classification Scheme

In addition to the functional categories assigned to assets, they are also classified by sensitivity level, which determines the degree of confidentiality and the scope of access controls required.

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

Shameless adopts a streamlined, two-tier sensitivity classification model: Public and Private. Given limited administrative overhead and the absence of a dedicated governance team, the organization prioritizes simplicity and clarity in its classification strategy. A more granular model, while effective in large enterprises, would impose unnecessary complexity on Shameless's lean operational structure.

- **Public** assets include information explicitly intended for broad distribution, such as marketing materials, press releases, and public website content. These assets do not require access restrictions and pose minimal risk if disclosed.
- **Private** assets encompass all data and systems requiring restricted access, including customer personally identifiable information (PII), internal HR records, financial data, infrastructure configurations, and legal documentation. Within this category, assets may be flagged as Confidential or Critical based on the potential impact of unauthorized disclosure, aligning with the company's internal risk register.

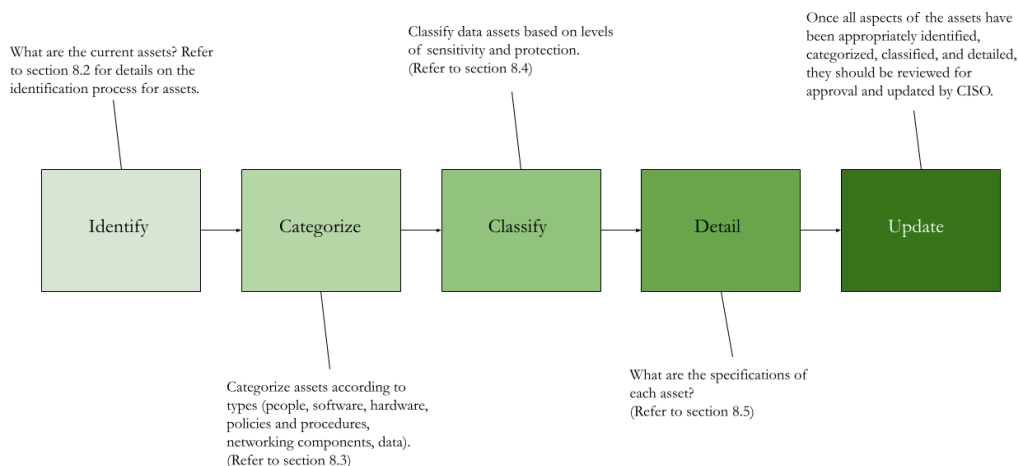
This classification approach enables Shameless to apply appropriate safeguards without burdening internal resources. It supports key principles of data governance, including need-to-know access, role-based security, and regulatory compliance with frameworks such as GDPR, CPRA, and HIPAA.

5.4. Identification, Storing, and Tracking

All categories and characteristics of the assets should be appropriately filled out and updated accurately. This spreadsheet will be used in the future to document any changes and keep accurate records of the assets. As such, the process for filling it out should be delegated to Alice Rose, the help desk and operations operative. Once the spreadsheet is filled out according to the process flow, it should be updated and reviewed for approval by CISO.

A weighted score for the impact of each asset will be calculated based on the weight given to 4 categories: revenue, productivity, cybersecurity, and reputation. The impact of assets on revenue, productivity, and cybersecurity are deemed to be the most important in the business continuity and success of Shameless, which is why they are weighted between 30-35% each. The impact on reputation was not considered to be as important, which is why it was given 5% weight. This weighted average measures the criticality of the asset and what should be prioritized.

5.5. Process Flow Chart



5.6. Recorded Asset Information Table

Hardware	Software	People	Policies and procedures	Data
Asset ID	Asset ID	Staff ID	Document number	Name
Asset value	Asset value	Position name	Document name	Classification
		Supervisor name and ID	Owner	Backup procedure active
		Security clearance level	Update frequency	Backup frequency
			Classification level	

5.7. Asset Criticality and Responsibility

Asset criticality is determined by evaluating the functionality, regulatory, and financial risks associated with each asset. The more significant the impact of the asset's failure, the higher its criticality level. Categorizing assets into varying levels of criticality allows Shameless to allocate security resources more efficiently and effectively, prioritizing assets accordingly.

There are 4 categories to measure the criticality and impact of an asset to the company: impact on revenue, productivity, cybersecurity, and reputation. Each measure should have different weight distributions because not all categories are impacted the same way from each asset. Accordingly, each category is not weighted the same; it would make sense that the impact on an asset's revenue, productivity, and cybersecurity (three major measures of a company's strength) should be about the same, but slightly more weight was given to productivity because a company

should aim to productively achieve its goals, and the assets are a vital way of measuring that. A company's reputation should also be considered, but it was given the least weight because it has the smallest impact on a company's strength and maturity level.

Impact on revenue	How much does the asset impact the revenue generated?
Impact on productivity	How does the asset affect the productivity of employees? The organization's business functions and operations?
Impact on cybersecurity	How much does the asset impact the organization's cyber security? How important are the asset's functions and security?
Impact on reputation	How does the asset influence the organization's reliability? How much do stakeholders and consumers value these assets? How might the misuse of such assets affect reputation?

Ex., impact on revenue could weigh 30%, impact on productivity 35%, impact on cybersecurity 30%, and impact on reputation 5%. The weighted score of each asset will be calculated by multiplying the score with the following percentage.

Example of calculating weighted score:

According to the Asset Registry, the company website (located in the software category) has an impact on revenue of 10, productivity 8, cybersecurity 9, and reputation 9.

Total weighted score = (revenue * weight) + (productivity * weight) + (cybersecurity * weight) + (reputation * weight)

$$10(0.3) + 8(0.35) + 9(0.3) + 9(0.05) = 3 + 2.8 + 2.7 + 0.45 = 8.95$$

This weighted average measures the criticality of the asset and what should be prioritized the most.

6. Risk Management

Risk assessment is an essential function within Shameless Consulting Ltd.'s ISMS. As a company that has already been through breaches and threats, it is critical that Shameless has a structured and proactive risk management approach to ensure the identification, analysis, and the continued mitigation of risks that could impact business operations, data security, and compliance.

The primary objective of the risk assessment is to provide a systematic method to evaluate potential threats and vulnerabilities across the company's infrastructure and business processes. It is not just for a compliance requirement, but a strategic approach that helps protect Shameless from financial, operational, and reputational damage. A well-implemented risk assessment framework enables the company to prioritize security investments, protect critical assets, and enhance resilience against threats. Additionally, regulatory compliance with standards such as GDPR, CRPA, PCI-DSS, and HIPAA ensures that Shameless remains compliant with industry mandates and avoids any potential financial and legal repercussions. Failure to meet these legal requirements can result in financial fines and penalties, legal liabilities, business disruptions, and reputational damage. To mitigate these legal risks, Shameless must integrate compliance-driven risk management and conduct regular audits to ensure compliance to all regulatory obligations. Refer back to section 2.6 for further description of legal obligations.

A comprehensive risk assessment process should be repeatable and continuously improved. By integrating risk assessment into daily business operations, Shameless can ensure ongoing security enhancements, incident prevention, and strategic risk mitigation. The risk management framework outlined in this document supports risk-aware decision-making, allowing Shameless to take a proactive approach against threats. The specific goals of this risk assessment are:

- Identification and security risks: recognizing security threats that could impact Shameless' assets, data, and systems.
- Evaluation of threats and vulnerabilities: assessing risks in the context of existing security measures and business operations.
- Determination of likelihood and impact: measuring the probability of a security event occurring and the potential business impact.
- Development of risk mitigation strategies: implementing appropriate controls to minimize risk exposure and enhance resilience.
- Regulatory compliance assurance: ensuring adherence to data security laws and frameworks.
- Establishment of a structured, repeatable process: creating a scalable approach that can be regularly reviewed and refined.

6.1. Risk Assessment Methodology

MT Consulting has carefully evaluated three widely-used risk assessment frameworks - NIST 800-30, ISO 27001, and OCTAVE - to determine the most suitable approach for its cybersecurity risk management. Each framework presents unique benefits and challenges, making it especially important to critically assess their effectiveness, scalability, and alignment with Shameless' business goals.

Framework	Key features	Benefits	Concerns
NIST 800-30	U.S. focus Framework used for federal information systems and organizations Four steps in risk assessment process (prepare, conduct, communicate, maintain)	Focuses solely on risk assessment No cost associated with use	Primarily used for U.S. government and organizations only No certification
ISO 27001	Risk treatment plans Assessment-based risk analysis Flexible implementation scheme: plan, implement, monitor, improve	Compliance driven Integrates with ISMS Supports ISO certification Widely recognized International standard Applicable to all organizations	Fee for certification Requires dedicated resources Commitment to long-term maintenance
OCTAVE	Self driven through internal teams Qualitative risk analysis Focus on business impact Three steps: Identify assets, assess vulnerabilities, mitigate risks	Advanced quantitative risk analysis not required which makes it easier for Shameless to implement Focuses on business risks, not just IT threats. Flexible across industry, company size, and organizational structure	Relies on qualitative assessments that may be less precise Prioritizing business risks over security can leave systems vulnerable to cyberattacks

6.1.1. NIST 800-30 as an Alternative

While NIST 800-30 was not the chosen risk assessment methodology for Shameless, it is one alternative that was considered. As the comparison table describes, it is primarily used to conduct risk assessment for U.S. federal government and organizations with unclassified information. The benefits to using NIST 800-30 include that it is free and easily accessible to use, but a concern was that it does not provide a certifiable standard for the company, hence why it was not chosen.

6.1.2. OCTAVE as an Alternative

OCTAVE was not selected for Shameless because it lacks structure and does not align with compliance requirements such as GDPR, CPRA, PCI-DSS. Qualitative risk analysis can lead to inconsistencies because risks are evaluated based on subjective judgment rather than quantitative measurable criteria. Additionally it is important to demonstrate compliance to regulators and business partners, however without certification Shameless cannot ensure the transparency and accountability Shameless needs to solidify its security standards.

6.1.3. ISO 27001: Compliance driven, Structured Approach

ISO 27001 is an internationally recognized standard for establishing, implementing, maintaining, and continually improving an ISMS. It provides a structured framework for organizations to manage and mitigate security risks while ensuring regulatory compliance with GDPR, CRPA, PCI-DSS, and HIPAA. ISO 27001 integrates risk management into a broader security governance framework, making it an appealing choice for companies looking to build a sustainable and scalable security program.

One key strength of ISO 27001 is its ability to enforce a risk-based approach to security, ensuring that the right amount of resources and security controls are implemented in proportion to the risks associated. It requires organizations to define their risk appetite, conduct risk assessments, and implement the appropriate controls to mitigate security threats. ISO 27001 also emphasizes documentation and auditability, making it easier for organizations to demonstrate compliance to regulators and business partners. For Shameless, this is a crucial advantage, and the company needs to adhere to regulatory requirements while also maintaining the trust of its customers and stakeholders.

By adopting ISO 27001's risk assessment methodology, Shameless can align itself with international security best practices and establish a strong foundation for future certification. This will not only reduce the likelihood of security breaches and compliance violations, but also position Shameless as a trusted and security-conscious organization.

6.1.4. Justification for ISO 27001: Why it is the best fit for Shameless

After a thorough evaluation, MT Consulting has chosen to adopt ISO 27001 as the primary risk assessment framework for Shameless Consulting Ltd. While the company is not yet ready for the full certification, it is a strategic long-term goal to prepare the organization for future compliance with international security standards. ISO 27001 provides significant benefits:

- Ensures adherence to GDPR, CPRA, PCI-DSS, and HIPAA
- Provides a repeatable risk management methodology for continuous security improvement
- Supports proactive rather than reactive security planning
- Enhances Shameless' reputation as a security-conscious organization

Given Shameless's recent security breaches, compliance failures, and lack of formalized risk management processes, ISO 27001 provides the most structured and practical approach to addressing these issues.

6.1.5. Implementing ISO 27001 as a Long-term Strategy

While Shameless is not immediately ready to pursue ISO 27001 certification, implementing its risk assessment methodologies will align the company with best practices and prepare it for eventual certification. By structuring risk assessments around ISO 27001, Shameless will be better equipped to improve regulatory compliance, avoid financial penalties, enhance operational resilience and business continuity, and foster security awareness across all members of the organization. Shameless' investment in ISO 27001 is a proactive decision that will drive security maturity and long-term risk management excellence.

6.1.6. Relation to NIST Cybersecurity Framework

There are 6 key components to the NIST Cybersecurity Framework:

- **Govern:** establishes the company's risk management strategy and policy
- **Identify:** determines the company's current cybersecurity risks
- **Protect:** uses controls and safety measures to reduce or eliminate risks
- **Detect:** provides findings and analysis of possible risks
- **Respond:** takes action in response to a cybersecurity incident
- **Recover:** restores assets and business operations impacted by cybersecurity incidents

The risk management process provided to Shameless relates to the second component of the NIST framework: identify. This is because risk management focuses on identifying, assessing, and managing risks.

6.2. Risk Factors

Risk assessment must account for both internal and external factors that can impact Shameless' security posture. A comprehensive understanding of these factors allows for the development of a proactive risk mitigation strategy that minimizes vulnerabilities and strengthens resilience.

6.2.1. Internal factors

Internal factors originate from within the organization and can be controlled or mitigated through policy changes, process improvements, and employee training.

- **Human error:** employee mistakes, phishing susceptibility, or insider threats due to negligence or malicious intent can lead to data breaches and operational disruptions.
- **Outdated systems and infrastructure:** legacy software, unpatched systems, and hardware failures introduce vulnerabilities that can be exploited.
- **Access control weaknesses:** weak password policies, misconfigured permissions, and poor privilege management increases the likelihood of unauthorized access.
- **Data mismanagement:** improper storage, transfer, or deletion of sensitive information can lead to regulatory non-compliance and financial penalties.
- **Security awareness deficiencies:** lack of cybersecurity training increases the risk of falling victim to phishing, ransomware, or social engineering attacks.
- **IT resource constraints:** limited staffing or budgetary constraints affect the organization's ability to implement advanced security solutions and threat monitoring systems.

Shameless has faced several internal risk factors that have directly impacted its security and operational resilience. Human error is a critical issue, as employees have fallen victim to phishing scams, exposing sensitive data. Outdated IT infrastructure has led to system failures and unpatched vulnerabilities. Access control weaknesses were highlighted when a former employee retains system credentials after termination. Data has also been mismanaged, with the customer database being breached, containing the details of 1000 clients and violating compliance regulations. The lack of cybersecurity awareness has exacerbated these risks, with weak passwords, social engineering threats, and unauthorized software installations. In addition, limited resources have made it difficult for Shameless to implement any response strategies, leaving security gaps for cybercriminals to exploit.

6.2.2. External Factors

External factors originate from outside the organization and are often beyond an organization's control. However, they must be accounted for to mitigate potential disruptions effectively.

- Cyber attacks: Phishing, malware, ransomware, denial of service, and zero-day exploits.

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

- Third party risks: vendors, contractors, and third-party service providers with weak security postures can introduce vulnerabilities to Shameless.
- Economic and market instability: economic downturns and budget cuts can affect security spending and resource allocation.
- Natural disasters and physical security risks: natural disasters can damage critical infrastructure, disrupting business operations.
- Political/geopolitical risks: international regulations, cyber warfare, and sanctions may influence security risk.

Cyber attacks have been the main external risk for Shameless, with denial of service attacks, databases being breached, phishing scams leading to accounts being brute-forced. Increasing security awareness and decreasing human error are good remedies against cyber attacks, as oftentimes cyber attacks are socially engineered.

6.2.3. Quantitative vs. Qualitative Risk Analysis

There are two defining types of risk analysis: quantitative and qualitative.

Quantitative analysis uses numbers and data to rate the severity of a risk. For instance, a scale from 0-10 may be used, 0 meaning no risk and 10 meaning critical risk. Quantitative analysis is objective and not easily subjected to dispute, since it relies on historical data, like patterns. While it is a detailed approach to risk classification, it can also require a lot of resources, such as time and money, that smaller companies may not be able to provide for risk analysis.

Qualitative analysis uses levels of risk, and one such hierarchy may be: insignificant, minor, moderate, major, and severe. These levels rate the significance of the risk and its impact. Qualitative analysis is often subjective and based on the individual's knowledge and perceived level of risk. While this may bring up concern about bias or inaccuracy, using a qualitative approach may be more helpful for a company like Shameless because it is easy to both identify and understand, and it can also act as a starting point to identify the severity of a risk, especially for companies or organizations without prior experience.

Shameless will use a semi-quantitative analysis. There are quantitative measures used in the risk register: the asset value, vulnerability likelihood, current control, uncertainty value, and average risk-rating value. These values provide useful information on the level of certainty, value, and likelihood of the risks associated with assets. However, as a small- to mid-sized company, it is also helpful for Shameless to use qualitative measures, especially for employees that may not have a prior understanding. As a result, measures like the impact of the risk (using low, medium, high) is adopted.

6.2.4. Impact of Risks

Risks can impact both Shameless and its stakeholders, including customers, investors, regulatory bodies, and business partners. As a company operating in the insurance sector, Shameless must recognize that risks extend beyond internal operations, affecting those who rely on the company for data protection. Failure in cybersecurity practices could have long-term repercussions, harming the company's reputation, finances, and legal standing while also placing stakeholders at risk.

The consequences of poor risk management can be severe. Financial losses may arise due to legal fines, regulatory penalties, operational disruptions, or cyberattacks. Reputational damage may occur if a security breach exposes customer data, erasing public trust and reducing the company's competitive edge in the market. Operational disruptions caused by security incidents, such as denial of service attacks can eliminate the usability of business functions. Additionally, legal liabilities resulting from non-compliance with regulatory requirements may lead to lawsuits, investigations, and regulatory actions, significantly impacting business continuity.

Stakeholders are also impacted by Shameless' risks. Customers are at risk of identity theft, fraud, and financial losses if their personal information is compromised. The exposure of sensitive information could result in monetary theft, credit fraud, or personal data misuse. Regulators closely monitor compliance with data protection laws, and failure to meet those requirements could lead to audits, penalties, and operational restrictions. Business partners and third-party vendors may experience supply chain disruptions if Shameless' cybersecurity weaknesses result in service or data issues, affecting mutual business interests. Investors may lose confidence in Shameless' as a company, leading to decreased company valuation and reduced capital investment.

6.2.5. Legal Requirements and Consequences of Non-compliance

Adhering to legal and regulatory frameworks is a non-negotiable requirement for Shameless. Failure to comply with security regulations can lead to severe consequences, including financial penalties, legal action, and reputational damage. Shameless is required to comply with the following regulations:

- GDPR: Protects personal data of EU residents, with fines of up to €20 million, or 4% of global annual turnover for non-compliance, whichever is higher.
- CPRA: Governs personal data protection in California, with fines of \$2,500-7,500 per violation.
- PCI-DSS: Enforces security standards for handling credit card transactions, with fines up to \$500,000 per data breach.
- HIPAA: Regulates healthcare data security, with fines up to \$1.5 million per violation per year.

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

6.3. Control Strategies

Once risks have been identified, they must be treated. Accordingly, there are five basic control strategies:

6.3.1. Transfer

This strategy shifts the risk to another asset, process, or organization. This typically occurs when the original holder of the risk cannot control it. As a result, the risk may be transferred by outsourcing other organizations, making changes to current services and deployment, or obtaining insurance. For Shameless, it may be wise to purchase cyber insurance for the company; although it sells the same insurance to customers, it would be equally beneficial for Shameless to have it as well.

6.3.2. Defense

This strategy, per its name, attempts to defend the organization or holder of the risk by preventing exploitation of the vulnerability initially. To defend, the company may choose to add further protection for its assets, both physically and digitally. For example, Shameless currently does not have physical security in its locations; it would be beneficial to implement ID scanners for employee-only access into the office, thereby preventing risk of theft and unauthorized access. Another method of defense may be to remove existing vulnerabilities in assets; for Shameless, it may be a priority to update and properly configure existing hardware, such as routers and firewalls, to ensure non-intrusion and eliminate risk of malware in the future. This idea may also apply to the assets of employees. By implementing user awareness training, the risk of phishing would greatly decrease.

6.3.3. Mitigation

This strategy attempts to reduce, or mitigate, the impact that the existing risk has already caused. It relies on the following three types of plans:

- **Incident response (IR):** Defined as the action taken by a company in response to the incident occurred. The plan includes detailed steps to act accordingly and is set into motion immediately once the incident occurs.
- **Disaster recovery (DR):** Defined as preparation taken to recover from the disaster occurred and often includes strategies and detailed instructions on how to do so. It may outline procedures to recover data that might have been lost as well as reestablishment of the appropriate services. DR begins immediately once the disaster is labeled as such.
- **Business continuity (BC):** Defined as plans to ensure the business will continue to operate in the event the disaster affects such operations. The company may deploy the

activation of another remote location. BC begins immediately after it is deemed that the disaster will affect business operations.

These plans are crucial in order to be able to identify and respond to attacks as soon as possible to mitigate the damage caused from disasters.

6.3.4. Acceptance

This strategy deems the best course of action is to simply accept the outcome of the risk and not protect it. It is reserved for specific instances only, and to use this strategy, the organization should have:

- Determine the level of risk
- Assessed the likelihood of the risk being exploited
- Estimated the possible damage from the attack
- Evaluated all potential controls for the risk
- Performed a cost-benefit analysis

This strategy is not recommended for Shameless, and should be reserved in the event the risk poses essentially no threat to the company.

6.3.5. Termination

This strategy is based on the company's decision to terminate, or eliminate, the asset that has any associated risks. This may occur in an instance where a certain asset has more risks than benefits, such as an outdated computer prone to malware.

6.4. Residual Risk

Residual risk refers to the level of risk that remains after mitigation strategies and security controls have been implemented. It acknowledges that not all risks can be fully eliminated. Some degree of exposure will always persist due to human error, system limitations, or evolving threat landscapes. For instance, while user awareness training significantly reduces the likelihood of successful phishing attacks, it does not guarantee complete immunity.

In the [risk register](#), the Residual Risk column has been intentionally left blank. Shameless has yet to apply any risk control strategies. However, it is expected to be filled out in the following years once strategies are implemented. Once mitigation actions are implemented, the organization will be able to re-evaluate each risk and document the residual risk accordingly.

6.5. Introduction to Risk Register (Risk Identification and Description)

The risk register is designed as a structured tool to identify and mitigate security risks associated with Shameless's assets. It ensures that threats and vulnerabilities are documented, analyzed, and addressed through appropriate security controls.

Identifying and describing risk is based on the risk management framework outlined in ISO 27001. ISO 27001's approach to risk identification consist of the following general steps:

- Identify assets
- Identify threats
- Identify vulnerabilities
- Assess likelihood & impact
- Determine risk treatment

Risks are also categorized based on key details to maintain structure and provide a centralized record of risks affecting company assets. The following sections provide an introduction and overview of the risk register.

6.5.1. Asset Identification

Asset ID: Identifies the specific asset (hardware, software, networking components, policies and procedures, or data) at risk. The ID assigned to each asset is unique and is a uniform way to identify all assets.

Asset Value: Determines the asset's importance to the business. This value was calculated by 4 main factors: impact on revenue (30%), impact on productivity (35%), impact on cybersecurity (30%), impact on reputation (5%). Each asset was ranked 1-10 for each category, 10 being the highest impact to get the weighted value of the asset overall.

6.5.2. Threat and Vulnerability Identification

Threat: The specific risk (unauthorized access, malware, data breaches). Use past security incidents, industry reports, and internal assessments to determine likely threats.

Vulnerabilities: The specific weakness that could be leveraged or exploited (Phishing, DDOS attack, weak access controls). Typically the first vulnerability has a higher likelihood of occurring. The risk register for Shameless includes two vulnerabilities for each asset; typically, the first vulnerability has a higher likelihood of occurrence.

6.5.3. Threat Exploitation Likelihood

Vulnerability likelihood rating (0-10): Probability of the vulnerability being exploited. A variety of factors are considered when assessing the likelihood of a vulnerability such as previous incidents, Shameless's current security posture, industry trends, and the simplicity of the exploitation. This risk register uses a rating between 0-10 because it is an easy scale to understand; 0 indicates a 0% chance of occurring and 10 indicates 100% chance of occurrence.

Likelihood Rating	Description	% Likelihood	Example
0	Not applicable	0% likely in the next 12 months	Will never happen
2	Rare	5% likely in the next 12 months	May happen once every 20 years
4	Unlikely	25% likely in the next 12 months	May happen every 10 years
6	Moderate	50% likely in the next 12 months	May happen every 5 years
8	Likely	75% likely in the next 12 months	May happen once every year
10	Certain	100% likely in the next 12 months	May happen multiple times a year

6.5.4. Threat Impact Classification

Impact (Low, medium, high): The level of damage that could occur if those vulnerabilities are realized. For simplicity, the threat impact classification only includes three levels of low, medium, and high.

Impact level	Description	Business and stakeholder impact	Color Code
Low	Minimal disruption	No loss of data, no loss of revenue, operations continue to function	Green
Medium	Some operational impact	Temporary downtime, which may result in loss of revenue or harm to reputation	Yellow

Impact level	Description	Business and stakeholder impact	Color Code
High	Major impact to business operations	Severe disruption in services, which may lead to regulatory penalties and loss of customers	Red

6.5.5. Risk Treatment

- **Current controls:** Security measures already in place.
- **Uncertainty value:** The level of security measures already in place measured in percentage. For Shameless, it is measured based on confirmation with the employees about the certainty of the control in place. For Shameless, this value is a percentage that falls between 0-20, 20 being the highest level of uncertainty. The reason why this range was chosen is because generally, it is not recommended to have above 20% uncertainty, although it is possible and does occur in some instances.
- **Risk rating calculation:** Determines risk based on likelihood, impact, and existing controls. Risk was calculated using the likelihood of the occurrence of a vulnerability multiplied by the value of the information asset minus the percentage of risk mitigated by current controls plus the uncertainty of current knowledge of the vulnerability.

Example:

Vulnerability	Likelihood	Asset Value	Current Controls	Uncertainty factor	Calculation	Risk Score
Vulnerability 1	8.05	10	0%	0%	$(8.05 \times 10) - 0 + 0$	80.5
Vulnerability 2	8.05	9	0%	0%	$(8.05 \times 9) - 0 + 0$	72.45

Final average: $(80.5 + 72.45) \div 2 = 76.48$

- **Risk treatment strategy:** Defines how the risk will be addressed (mitigation, defense, transference, acceptance, and termination). Further details about each strategy are listed in section 6.3.
- **Recommended controls:** Suggests security improvements for Shameless to implement.
- **Risk control:** Connects each risk to specific security controls from ISO 27001.
- **Risk owner:** Person/department responsible for managing identified risk.
- **Residual risk:** The risk that remains after applying recommendations and the appropriate risk control strategies measured in percentage. Further details about the residual risk are listed in section 6.4.

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

By following the same steps for each category in the risk register, Shameless can ensure consistent, valid, and comparable results when completing it in the future.

6.6. Threats and Vulnerabilities: Confidentiality, Integrity, and Availability

Determine if the threat impacts confidentiality, integrity, or availability and mitigate accordingly.

CIA Principle	Definition	Example of Threats	Example of Vulnerabilities
Confidentiality	Restricting access to data to authorized users only	Unauthorized access	Weak access controls, weak passwords, lack of encryption, malware
Integrity	Data remains accurate and unaltered	Data breaches	Unpatched Software, lack of access controls, lack of encryption
Availability	Ensure systems and data remain online and accessible	Disruption of services	DDoS attacks, hardware failures, software failures, ransomware, natural disasters, loss of power

6.7. ISO 27001 Clauses

Information security risk assessment	Description	Section
Clause 6.1.2		
6.1.2a	Establishes and maintains information security risk criteria that include: 1) the risk acceptance criteria; and 2) criteria for performing information security risk assessments;	Refer to 6.5.3, 6.5.4
6.1.2b	Ensures that repeated information security risk assessments produce consistent, valid and comparable results;	Refer to 6.5.5

6.1.2c	Identifies the information security risks: 1) apply the information security risk assessment process to identify risks associated with the loss of confidentiality, integrity and availability for information within the scope of the information security management system; and 2) identify the risk owners;	Refer to 6.5.1, 6.5.2, 6.5.5
6.1.2d	Analyses the information security risks: 1) assess the potential consequences that would result if the risks identified in 6.1.2 c) 1) were to materialize; 2) assess the realistic likelihood of the occurrence of the risks identified in 6.1.2 c) 1); and 3) determine the levels of risk;	Refer to 6.5.4, 6.5.3, 6.5.5
6.1.2e	Evaluates the information security risks: 1) compare the results of risk analysis with the risk criteria established in 6.1.2 a); and 2) prioritize the analysed risks for risk treatment.	Refer to 6.5.5
Information security risk treatment Clause 6.1.3	Description	Section
Clause 6.1.3a	Select appropriate information security risk treatment options, taking account of the risk assessment results.	Refer to 6.3, 6.4

7. Incident Response

An incident management system is an essential function within Shameless Consulting Ltd's ISMS. As a company that has already experienced breaches and threats, it is critical that Shameless adopts a structured and proactive incident management approach to ensure the identification, containment, eradication, and recovery from events that could jeopardize business operations, compromise sensitive data and breach regulatory obligations.

The primary objective of an incident management system is to provide a systematic and repeatable method to respond to incidents efficiently while minimizing operational disruption and legal exposure. A well-implemented incident response framework will allow Shameless to prioritize mitigation efforts, contain breaches early, and build organizational resilience while also protecting Shameless from financial, operational, reputational, and legal damage.

Shameless must demonstrate regulatory compliance with legal requirements such as GDPR, CPRA, PCI-DSS, and HIPAA, each of which imposes specific requirements such as breach detection, containment, and documentation. Failure to meet these requirements can result in financial penalties, reputational damage, and legal liability.

A mature incident management framework supports the continual improvement cycle defined by ISO 27001, allowing Shameless to make risk-based decision-making that strengthens security operations over time. The system also reinforces the risk assessment framework by ensuring that identified vulnerabilities are addressed accordingly and prevented from recurring. The key benefits of implementing a comprehensive incident management system includes:

- Rapid detection and response to security threats.
- Minimized downtime and business disruption.
- Efficient communication and decision making during critical incidents.
- Accountability and documented procedures, ensuring incidents are handled consistently
- Regulatory compliance with GDPR, CPRA, PCI-DSS, and HIPAA.
- Improved employee awareness through training.

7.1. Framework Selection: NIST 800-61

Shameless Consulting Ltd. will adopt the NIST 800-61 as its incident management framework. This framework is specifically designed to assist organizations in creating an incident response capability. It includes four major phases: Preparation, **Detection and Analysis**, **Containment/Recovery**, and **Post-Incident Activity**.

7.1.1. Why NIST 800-61?

The NIST 800-61 framework is particularly well-suited for Shameless Consulting Ltd. due to its structured and adaptable approach to incident response techniques. As an industry-proven model, the NIST 800-61 provides a full lifecycle methodology, from preparation, detection, containment, eradication, and post-incident activity, ensuring that all critical stages of incident management are addressed in a consistent and repeatable manner.

For a mid-sized organization like Shameless, which has experienced multiple data-related incidents and is working towards ISO 27001 readiness, NIST 800-61 offers a level of structure that can be scaled to fit both the resource constraints that Shameless may have as well as the

future growth of the organization. It aligns with ISO 27001 Clause 6.1.3 (select appropriate information security risk treatment options, taking account of the risk assessment results), which helps Shameless structure its response capabilities. NIST emphasizes on documentation, lessons learned, and continuous improvement, supporting Shameless' objective of operational maturity and regulatory compliance.

Moreover, this framework supports the integration of existing security tools such as Security Information and Event Management (SIEM) and Intrusion Detection System/Intrusion Prevention System (IDS/IPS), allowing the company to leverage automation to reduce detection and response times. By adopting the NIST 800-61, Shameless will not only be adequately prepared to combat current threats, but also establish a proactive, scalable, and auditable incident response system that places the organization for sustained compliance and stakeholder trust.

7.1.2. Framework Comparison (NIST 800-61 vs. SANS Incident Handler's Handbook)

Below is a table comparison between the NIST 800-61 and SANS Incident Handler's Handbook frameworks. While the SANS framework offers clarity and is helpful for operational teams, NIST's approach is more structured, scalable, and aligned with compliance needs.

Criteria	NIST 800-61	SANS
Preparation	Emphasizes training, incident categories, policies	Strong focus on readiness but not as structured
Detection analysis	SIEM, IDS/IPS, endpoint data	Relies on logs and alerts, unknowns may bypass
Containment and eradication	Multiple containment strategies	General recommendations
Recovery	Tested backups and restoration paths	Less emphasis on restoration
Post-incident activity	Requires reporting, root cause analysis, improvement	Focused on immediate recovery
Scalability	Easy to scale for all organization sizes	Large organization may need adaptation
Documentation support	Templates and real-world examples	Not as much as NIST

7.1.3. Addressing NIST Shortcomings

To address the resource-intensiveness of the NIST model, Shameless will integrate automation where possible (ex., SIEM, IDS/IPS) and leverage external incident response specialists during high-severity events.

7.2. Defining and Classifying Security Incidents

Definition: A security incident is any attempted or actual unauthorized access, use, disclosure, disruption, modification, or destruction of information systems.

Classification:

Incidents will be classified into five tiers:

- **Critical:** National or regulatory breach (ex., GDPR violation).
- **High:** Large data breach or ransomware attack.
- **Moderate:** Isolated malware infection.
- **Low:** Unauthorized access attempt or phishing email.
- **Informational:** Alert-only events with no threat confirmed.

7.3. Detection and Reporting Tools

An effective incident response is only as strong as the organization's ability to detect and report threats early and accurately. Timely detection and accurate reporting are core to Shameless' incident response process. To achieve this, the company will implement a multi-layered detection strategy that integrates advanced monitoring tools, user awareness, and automated alerting systems.

7.3.1. Detection Tools

- **Security Information and Event Management (SIEM):** Aggregates and correlates logs from servers, endpoints, and network devices, providing real-time visibility into potentially malicious activity.
- **Intrusion Detection and Prevention Systems (IDS/IPS):** Monitors incoming and outgoing network traffic to detect suspicious patterns such as port scanning, brute-force attempts, and known malware signatures. IPS allows for automated blocking of confirmed threats.
- **Endpoint Detection and Response (EDR):** Deployed on laptops, desktops, and servers to detect abnormal file activity, privilege escalation, and lateral movement across systems. Supports forensic analysis.

- **Email Gateway Security:** Given Shameless' exposure of phishing attacks, a secure email gateway will be configured to scan incoming and outgoing messages for malicious links, attachments, and spoofed addresses. It will also have an incident response automation for flagged emails.

7.3.2. Reporting Mechanisms

- **Automated SIEM alerting:** Critical events will generate alerts automatically routed to the cybersecurity analyst department and logged into the incident tracking platform. To enhance this capability, two SIEM solutions have been evaluated: Splunk and IBM QRadar.

Feature	Splunk	IBM QRadar
Ease of use	Customizable but steep learning curve	Streamlined interface
Threat detection	Good with custom rules, real time correlation	Built-in correlation rules and threat intelligence integration
Cost	Expensive licensing, cost scales with data volume	More cost-effective at scale, licensing based on data sources
Integration	Integration ecosystem includes AWS, Azure, Google Cloud	Integration with IBM ecosystem, third-party support
Dashboards	Advanced customizable dashboards	Pre-built templates
Best use case	Complex environments	Mid-sized organizations

While both platforms provide robust capabilities for incident detection and alerting, QRadar is the better choice for Shameless, given its more intuitive setup and cost effective structure.

- **Help desk escalation:** Users encountering suspicious activity (ex., phishing emails, ransomware) will be instructed to contact the help desk and operations operative.
- **Security awareness portal:** Employees will have access to a dedicated portal or form for reporting incidents. Submissions will trigger triage procedures.
- **Third-party notifications:** Vendors and service providers will be contractually obligated to report relevant security incidents in a timely manner.

7.4. Incident Response Metrics

Measuring the effectiveness of Shameless Consulting Ltd.'s incident response program is critical for demonstrating security maturity, improving resource allocation, and supporting the ISO 27001 continual improvement model. Performance metrics provide clear, objective indicators of how efficiently incidents are detected, triaged, resolved, and reviewed as well as ensuring accountability, validating the return on investment for security tools and personnel.

Accurate measurements are imperative for Shameless to justify adjustments in budgeting or staffing and to identify whether training, tooling, or where workflow changes are needed. Incorporating incident response metrics into dashboards allows management to make informed decisions that align with organizational risk tolerance and business objectives. When regularly reviewed, metrics can drive improvements through the Plan-Do-Check-Act (PCDA) cycle, enforcing the ISO 27001 continuous improvement model, ensuring that response efforts stay effective and scalable.

7.4.1. Key Performance Indicators (KPIs)

- **Mean Time to Detect (MTTD):** Measures how quickly an incident is identified after it begins. Lower values indicate strong monitoring and early detection.
- **Mean Time to Respond (MTTR):** Average time from detection to full resolution. Helps evaluate how efficiently incidents are contained and mitigated.
- **Number of Incidents Detected Monthly:** Tracks volume trends, helping anticipate staffing or process needs.
- **False Positive Rate:** Indicates the percentage of alerts that do not lead to confirmed incidents.
- **Compliance Violation Count:** Tracks number of times an incident results in a breach of regulatory obligations. Useful for demonstrating accountability and improving legal defensibility.

Monitoring these KPIs will allow Shameless to measure incident response effectiveness, allocate resources efficiently, and fulfill the ISO 27001 continual improvement principle.

7.5. Documentation and Response Roles

Proper documentation of incidents is crucial to supporting regulatory reporting, enabling lessons learned, and improving future incident response practices. Shameless Consulting Ltd. will adopt a documentation protocol that integrates automated and manual tools to ensure consistency, accountability, and compliance.

7.5.1. Documentation Tools

- **Incident Tracking System (ex., JIRA Service Management):** Centralized logging system that records incident identifiers, timestamps, responsible parties, resolution stages, and outcomes.
- **Incident Report Template:** A standardized form capturing essential incident information such as detection source, classification level, affected systems, containment measures, mitigation efforts, recovery timeline, and verification results.
- **Lessons Learned Summary:** Post-incident analysis document used in debriefing sessions, highlighting root causes, security gaps, and action items for remediation and prevention.
- **Regulatory Notification Template (ex., GDPR 72-hour form):** Structure communication templates that ensure timely and complaint reporting to data protection authorities within stipulated timeframes. (ex., 72 hours for GDPR)

7.5.2. Contingency Plan Management Team (CPMT)

The CPMT and designated response team will lead incident handling activities. Each member has defined responsibilities and escalation authority. Coordination will follow a chain-of-command approach, ensuring timely and clear decision making during a security event.

- **CEO:** Approves external communications, regulatory disclosures, and high-level strategic decisions.
- **Head of IT:** Oversees IT system dependencies, allocates response resources, and acts as incident commander.
- **Cybersecurity Analyst:** Leads threat analysis, triage, and technical remediation steps. Updates SIEM rules.
- **Network Manager:** Executes network containment such as VLANs or endpoints.
- **Data Protection Officer:** Ensures privacy and regulatory obligations are fulfilled. Manages reporting to regulators.
- **Help Desk & Ops:** Coordinates user communication, user reports, and incident portal tracking.

7.5.3. Flow of Decision-Making

A flowchart will be created with:

1. Incident detection
2. Escalation to CPMT
3. Classification
4. Initial containment
5. Eradication

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

6. Recovery
7. Resolved?
 - a. No
 - i. External incident report (IR) specialist
 - ii. Back to step 5
 - b. Yes
 - i. Post-incident review

Examples of the incident response templates can be found [here](#).

7.6. Incident Response Walkthrough: Brute-Force & Phishing Attack

7.6.1. Case Summary

In the case study, a **support technician's email account was brute-forced**, and a phishing email was sent to the database administrator (DBA). The DBA clicked a malicious link, logged into a spoofed site, and **leaked credentials**. This enabled the attacker to escalate privileges and gain unauthorized access to the client database. "Personally identifiable information of over 1000 clients" was accessed and later found on reddit. This breach represents a severe violation of data protection laws, GDPR and CPRA in particular which exposes Shameless to legal, financial and reputational risks.

7.6.2. Using NIST 800-61 Methodology

7.6.2.1. Preparation

In preparation, regular cybersecurity training is delivered through a learning management system (LMS), such as Easy LMS, featuring interactive modules that educate staff on phishing, password hygiene, secure login practices, and the proper reporting of suspicious activity. These are supplemented with recurring phishing simulations orchestrated by the cybersecurity team using tools like PhishingBox and internal security awareness campaigns.

To support technical preparedness, Multi-Factor Authentication (MFA) is enforced across all email accounts and remote access tools, while strong password policies mandate a minimum length of 16 characters, routine expiration, and checks against known breached credentials. Mobile Device Management (MDM) tools are applied to both company-owned and authorized personal devices to enforce encryption standards. Additionally, DNS filtering blocks access to known malicious domains.

Detection capabilities are improved via a Security Information and Event Management (SIEM) platform configured with baseline models of normal login behavior and brute-force detection rules. Logs are aggregated from firewalls, IDS, servers, endpoints, cloud environments, and

VPNs, then normalized to allow for cross-system correlation and analysis. Behavioral analytics establish a model of standard employee activity (login times and data usage) so the SIEM can flag anomalies like logins from unexpected locations or sudden data transfer spikes. Event correlation logic is embedded within the SIEM, triggering alerts when a series of suspicious activities (ex., multiple failed login attempts followed by success from the same IP) are detected. Alerts are tiered and routed to the cybersecurity analyst, Jessica Chan, with predefined response timeframes: 30 minutes for critical incidents and one hour for high-severity alerts. Maya Patel, the Data Protection Officer (DPO), ensures documentation is in line with legal obligations, including GDPR's 72-hour breach notification requirement.

The Contingency Plan Management Team (CPMT) also plays a vital role in incident readiness. CEO Leroy Mackenzie approves strategic plans and ensures executive support. Vivian Rosewater, Head of IT, oversees system readiness and coordinates IR resources. Jessica Chan, the Cybersecurity Analyst, configures SIEM rules, gathers threat intelligence, and runs phishing simulations. Network Manager Steve Sidebottom is responsible for patch management and ensuring visibility through system logging. Maya Patel, the DPO, aligns incident management with regulatory compliance. Alice Rose and Frank Grey, representing the Help Desk and Operations, are trained to handle reporting workflows and escalate issues.

7.6.2.2. Detection and Analysis

The detection of security incidents is primarily handled through the organization's SIEM system, which correlates abnormal patterns such as unauthorized login attempts, unusual login times or geolocations, and brute-force attack sequences. For example, a phishing email sent from a compromised technician's account may be identified due to anomalies in login behavior. Upon detection, the SIEM automatically alerts Jessica Chan, the Cybersecurity Analyst.

Jessica then begins the analysis phase by reviewing logs from the email gateway to trace the phishing email's origin and reach. Endpoint detection and response tools help determine which users interacted with the malicious content.

7.6.2.3. Containment, Eradication, and Recovery

Containment: Disabling compromised accounts, quarantining phishing emails, and isolating affected devices, particularly those used by the support technician and the DBA. Devices are placed on forensic hold for further analysis.

Eradication: Resetting user credentials, forcing logouts, scanning systems for persistent threats such as malware or backdoors, and applying patches to Exchange servers, Active Directory, and firewall systems. Firewall rules are also reviewed and updated.

Recovery: Restoring the affected customer database from a secure, verified backup. System logs and application integrity are validated, post-incident analysis is extended to cloud and VPN access logs. New SIEM rules are deployed to detect similar attack vectors in the future, and all affected devices are re-enrolled in MDM with enforced encryption.

7.6.2.4. Resolution Criteria

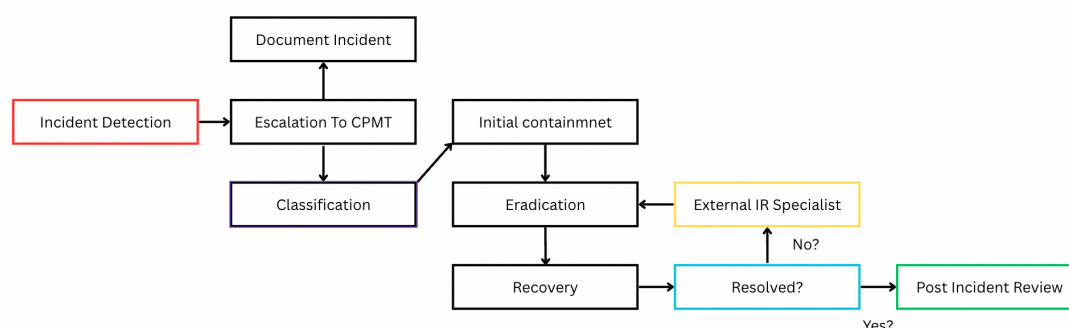
An incident is considered resolved once access has been revoked, systems are restored, and no indicators of compromise remain. If residual risks or unresolved anomalies persist, the matter is escalated to an external incident response partner for further investigation.

7.6.2.5. Post-incident Activity

After resolution, a post meeting is conducted involving the CPMT and affected departments. This session documents the full attack lifecycle, including the entry point, internal movement, data accessed, and response timeline. Lessons learned from the incident are used to refine training modules, update phishing and password policies, and improve SIEM brute-force detection rules.

Company-wide enforcement of MFA is reaffirmed, and full-disk encryption is mandated across all devices. The risk register is updated to reflect the identified exploit path and residual risks. Finally, the DPO formally notifies the appropriate regulatory bodies within 72 hours, ensuring compliance with breach disclosure regulations such as the GDPR.

7.6.2.6. Incident Response Flow Diagram



8. Policies

In an ISMS, effective documentation is important in ensuring consistency, accountability, and alignment with Shameless Consulting Ltd.'s goals. Each documentation (Standards, Policies, Best practices, Procedures) type serves a different purpose and is targeted toward a specific

audience within the organization, helping build a framework that supports regulatory compliance, operational efficiency, and clear communication across departments.

- **Policy:** A policy document outlines the organization's position on a specific issue. Policies set the strategic direction and state the organization's intent, commitments, and expectations regarding security. They are written for senior management, department leads, and auditors to ensure clarity and direction for compliance, governance, and risk mitigation. Policies typically address what needs to be done, not on how to do it.
- **Standard:** A standard provides mandatory technical or operational requirements that support the implementation of a policy. Standards translate policy statements into actionable criteria. For example, if a policy mandates multi-factor authentication, the standard would specify the acceptable methods. They are written for system administrators, engineers, and technical managers. Standards promote consistency and ensure compliance is measurable and enforceable.
- **Best Practice:** Best practices are industry-recognized methods or guidelines that promote optimal performance while reducing risk. They are not mandatory but offer recommended ways to comply with policies and standards. Best practices are often flexible and evolve with technology and threats. This document is often used in staff training, awareness initiatives, and reference guides.
- **Procedure:** A procedure is a step-by-step guide describing how a policy or standard should be implemented in practice. Procedures are highly specific and are written for end-users, help desk staff, and IT teams to execute. Procedures ensure consistency, reduce human error, and support compliance audits. They are especially important for critical or repetitive tasks like incident response, where precise execution determines the difference between containment and escalation.

8.1. Policy Selection

The policies selected for Shameless Consulting Ltd. are based on an analysis of the cybersecurity incidents and vulnerabilities outlined in the case study. These incidents include unauthorized access via brute force, phishing, malware infections (such as Emotet and Line Dancer), the use of unmonitored personal devices, and the absence of cybersecurity training. The selected policies are strategically aligned to address the most critical gaps in Shameless's security posture, support regulatory compliance, and strengthen the foundational layers of the organization's ISMS.

Each policy is chosen for its direct relevance to observed threats, operational weaknesses, and the anticipated future state of Shameless as it moves toward ISO 27001 readiness. The table below presents the rationale behind each policy and maps it to specific ISO 27001 Clauses and Annex A controls. This ensures Shameless's policies are aligned with industry best practices and internationally recognized security standards, positioning the company for future audits, certifications, and internal accountability.

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

Policy Name	Justification	ISO 27001 Mapping
Acceptable Use Policy (AUP)	Staff using personal devices, insecure mobile access, loss of devices.	Clauses 6.1.3 (Risk Treatment), Annex A 5.10 (Acceptable Use), 5.9 (Inventory of Assets), 5.15 (Access Control)
Access Control Policy	Weak password hygiene, lack of least privilege. Credential brute force incidents.	Clauses 5.15 (Access Control), 5.1 (Leadership), 6.1.3 (Risk Treatment), Annex A 5.18 (Access Rights), 5.16 (Identity Management), 8.5 (Secure Authentication)
Data Classification and Handling Policy	Absence of structured rules for managing sensitive client information and internal records, mishandling of user data	Clauses 6.1.3 (Risk Treatment), 8.1 (Operational Planning and Control), Annex A 5.12 (Classification), 5.13 (Labeling), 5.14 (Handling)
User Awareness and Training Policy	Lack of staff training on phishing and malware awareness, no LMS, no onboarding	Clauses 7.2 (Competence), Annex A 6.3 (Awareness, Education, and Training), 6.8 (Incident Reporting)

Data Classification and Handling Policy

Shameless Consulting Ltd.

MT Consulting

Author: Mark To

May 4, 2025

For internal use only

Version	Date	Author	Summary of Change
1.2	05/04/2025	Mark To	Added and updated Data Classification and Handling Policy

Data Classification and Handling Policy

Purpose

The purpose of this policy is to establish a standardized approach for identifying, classifying, labeling, and handling information assets across Shameless Consulting Ltd. This ensures that all data is managed according to its level of sensitivity, regulatory requirements, and business value. By defining consistent rules and responsibilities for data stewardship, this policy helps prevent unauthorized access, data loss, and misuse. This policy is also designed to support the organization's compliance with data protection regulations such as GDPR, CPRA, HIPAA, and PCI-DSS, while aligning with best practices under ISO 27001. Through structured classification and handling Shameless aims to enhance operational efficiency, mitigate data security risks, and instill a culture of accountability throughout the organization.

Scope

This policy applies to all employees, contractors, and partners, and third-party vendors who access, manage, store, or process information owned or controlled by Shameless Consulting Ltd. It covers all data types including digital, printed, structured, and unstructured formats across all platforms (cloud, on-premise, hybrid environments). It also applies to data at rest, in transit, and in use.

Data Classification Levels

All information assets must be classified into one of the following categories:

- **Confidential (Private):** Highly sensitive data such as customer PII, financial records, source code, and legal documents, Unauthorized access may lead to regulatory penalties or reputational harm.
- **Internal Use Only (Private):** Business-critical information intended for use within Shameless but not for public disclosure. Includes HR files, internal reports, and system configurations.
- **Public:** Information intended for external release, including marketing materials, public website content, and published press releases.

Handling Requirements

- **Private**
 - Must be encrypted in transit and at rest.
 - Access granted only to authorized personnel via role-based access controls.
 - Stored on systems compliant with ISO 27001 Annex A 5.12-5.14.
 - Backup and recovery procedures must include retention audit logs.

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

- Shared internally through secure channels (ex., SharePoint with 2FA).
- No forwarding to personal email accounts or third parties without Data Protection Officer approval.
- **Public**
 - Reviewed and approved by the Legal department prior to publication.

Data Inventory and Tracking

Shameless will maintain a centralized data inventory platform integrated with its asset management system. This platform will:

- Record classification, cost, and impact/importance of each asset.
- Support automated discovery and classification with asset tags.

Data Retention and Disposal

- All data must be retained only for the duration justified by business or legal necessity.
- Expired data must be secretly deleted using NIST 800-88 standards.
- Data archiving must follow guidelines defined by the Data Ownership and Legal teams.

Monitoring and Compliance

- Classification and handling practices will be subject to periodic audits.
- Violations may result in disciplinary action as per HR policy and may invoke breach response protocols.
- Access to high-sensitivity datasets will be logged and monitored.

Policy Sanctions

Failure to comply with this policy may result in sanctions such as mandatory training, revocation of access rights, formal disciplinary action, or legal consequences, depending on the severity of the violation. Consistent enforcement ensures data remains a managed and protected asset of Shameless Consulting Ltd.

Acceptable Use Policy

Shameless Consulting Ltd.

MT Consulting

Author: Mark To

May 4, 2025

For internal use only

Version	Date	Author	Summary of Change
1.2	05/04/2025	Mark To	Added and updated Acceptable Use Policy

Acceptable Use Policy

Purpose

The purpose of this policy is to outline the acceptable use of electronic devices, computing resources, and network systems at Shameless Consulting Ltd. These guidelines are designed to protect employees and the company from cybersecurity risks, including but not limited to malware attacks, phishing, unauthorized access, and data loss. This policy supports our broader Information Security Management System (ISMS) and ensures alignment with ISO 27001 Annex A Control 5.10 on acceptable use.

Scope

This policy applies to all employees, contractors, consultants, interns, and third-party personnel who use, access, or manage Shameless-owned or Shameless-connected devices, information systems, or data repositories. The policy covers both on-site and remote access, including use of personal devices under BYOD (Bring Your Own Device) arrangements.

General Use and Ownership

- All proprietary information stored or transmitted via company devices and services is the property of Shameless Consulting Ltd.
- Users must ensure that sensitive data is encrypted and stored in compliance with the company's Data Protection Policy.
- Devices must be secured with password-protected lock screens, with automatic locking enabled after 10 minutes of inactivity.
- Employees must report the theft, loss, or suspected compromise of devices immediately to the IT department.
- Personal use of company systems should be reasonable, occasional, and not interfere with business operations.

Security and Proprietary Information

- All endpoints connecting to the internal network must comply with the company's Least Access Privilege.
- Passwords must comply with the Password Policy and should not be shared.
- Remote work devices must include endpoint protection software (ex., **CrowdStrike Falcon**) and full-disk encryption.
- Employees are prohibited from posting confidential company information on public forums or social media.

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

Unacceptable Use

- Use of unlicensed or pirated software.
- Bypassing security mechanisms (ex., firewalls, VPN restrictions).
- Introducing malware into company systems (ex., email attachments or USB drives).
- Unauthorized access to systems, networks, or databases not explicitly required for one's role.
- Use of company resources to engage in illegal activity or harassment.
- Sharing credentials or allowing others to access company systems using your credentials.
- Transmitting offensive, obscene, or discriminatory content.
- Misuse of personal devices to store company data without approval from IT.

Social Media and Email Conduct

- Employees must include disclaimers on personal social media or blog posts stating views are their own.
- Use of corporate email for chain letters, spam, or personal solicitations is forbidden.
- Email attachments should be scanned before opening.

Monitoring and Enforcement

- The IT departments reserves the right to audit and monitor system usage for security compliance.
- Violations of this policy may lead to disciplinary actions, up to and including termination.
- Legal action may be pursued in cases involving criminal conduct of negligence.

Exceptions

- Any exception to this policy must be approved in writing by the Head of IT and the Cybersecurity Analyst and will be documented with a formal risk assessment.

Policy Sanctions

Non-compliance with this policy will be subject to enforcement based on Shameless' HR disciplinary matrix. Sanctions may include mandatory retraining, suspension of access rights, formal warnings, or termination, depending on the severity and frequency of the violation. Legal consequences may also apply for breaches of law.

Related documents

This document is related to the Acceptable User Procedure.

Acceptable Use Procedure

Shameless Consulting Ltd.

MT Consulting

Author: Mark To

May 4, 2025

For internal use only

Version	Date	Author	Summary of Change
1.2	05/04/2025	Mark To	Added and updated Acceptable Use Procedure

Acceptable Use Procedure

Procedure

This procedure supports the Acceptable Use Policy by providing clear, practical steps that all Shameless Consulting Ltd. employees and contractors must follow when using company-provided and personal devices to access corporate systems and data.

Scope

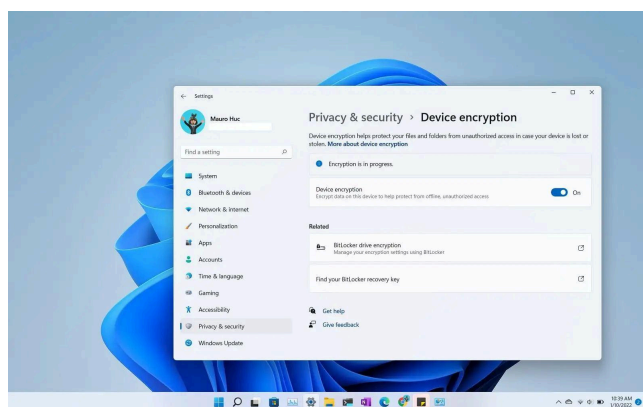
This procedure is written for all non-technical staff, including operational personnel, HR, sales, marketing, and remote workers, as well as contractors using company systems. Technical staff should refer to the relevant standards and guides maintained by IT.

Device Setup Checklist

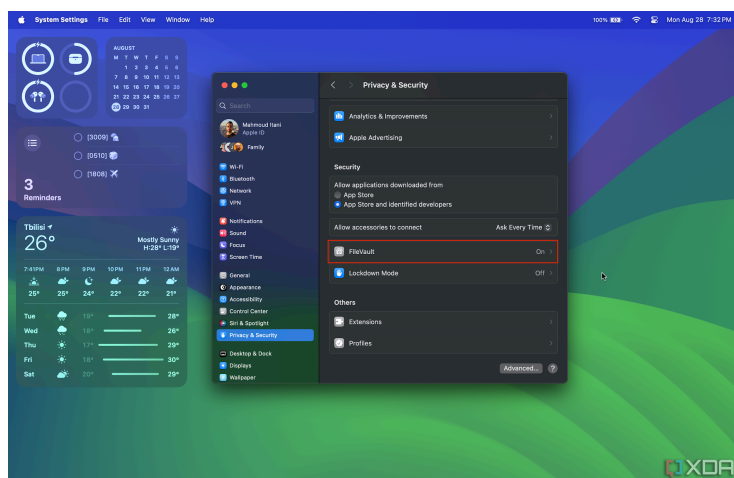
Before accessing any Shameless system, employees must:

- Ensure device encryption is enabled. (Use BitLocker for Windows or FileVault for macOS)
- Install approved antivirus software. (CrowdStrike Falcon or Windows Defender)
- Enable automatic software updates for operating systems and all critical applications.
- Set up a strong password and enable auto-lock with a 10 minute timeout.

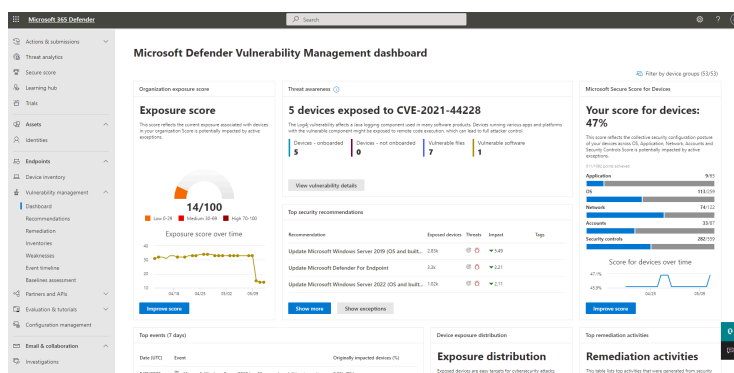
BitLocker:



FileVault:



Windows Defender:



Secure Network Access

- Connect only to trusted, password-protect Wi-Fi networks.
- Use the company-approved VPN when working remotely.
- Avoid using public hotspots unless a mobile hotspot is available.

Acceptable and Unacceptable Use Checklist

Activity	Allowed?	Description
Personal browsing during breaks	Yes	Must not interfere with productivity or bandwidth
Using unauthorized USB storage devices	No	Only encrypted, approved USBs permitted
Sharing login credentials	No	Strictly prohibited
Posting confidential files to	No	Only Sharepoint or approved

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

Dropbox		cloud services allowed
Logging into work email via public PC	No	Strictly prohibited; use secured personal device only

Reporting Incidents

If any of the following events occur, immediately report them to the Help Desk:

- Device lost or stolen
- Accidental disclosure of sensitive data
- Suspicious email or software activity
- Unauthorized access attempts

Email helpdesk@shameless.com or use the “Report and Incident” button on the company website.

Incident Report Form:

CYBERSECURITY (IT) INCIDENT REPORT FORM

Use this form to report any cybersecurity issues, breaches, hacks, malware, or any other incidents involving a 3rd party.

Date of Report: _____, 20____

CONTACT PERSON

Full Name: _____ Address: _____

Job Title: _____

Phone: (____) _____ E-Mail: _____

THE INCIDENT

Date of Incident: _____, 20____ Time: _____ AM ☐ PM ☐

Type of Incident: ☐ Malware ☐ Data Breach ☐ Other: _____

How was the incident detected / discovered? _____

NOTIFICATION

Were other personnel notified? ☐ Yes ☐ No

If yes, enter: _____

CONTAINMENT

Were any containment measures made? ☐ Yes ☐ No

If yes, describe: _____

IMPACTED SERVICES

Was anything permanently impacted by the incident? ☐ Yes ☐ No

If yes, describe: _____

Ongoing User Awareness Training

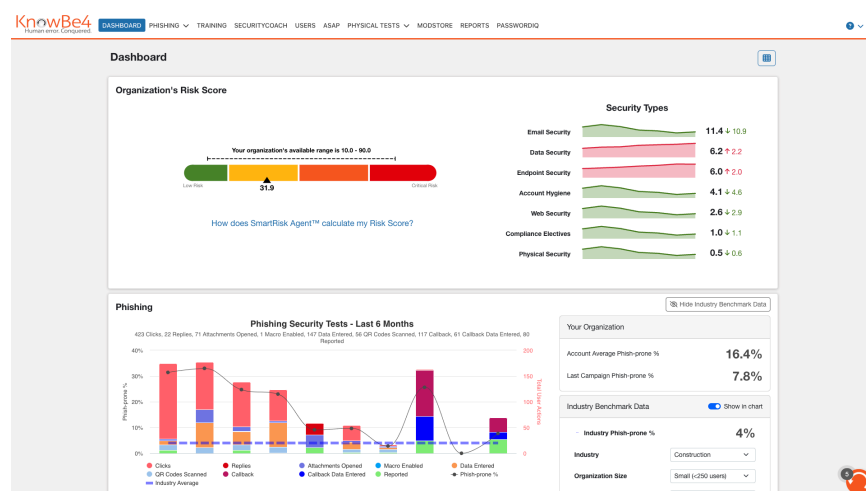
To reinforce acceptable use, all staff must:

- Complete a cybersecurity awareness course via the LMS (ex., KnowBe4, Moodle) annually.
- Participate in quarterly phishing simulations.
- Review policy and procedure changes communicated by IT.

MT Consulting | Confidential | Version 1.4 | Last Updated: 12-May-2025

This document contains sensitive information. Unauthorized distribution is prohibited.

KnowBe4:



Exceptions

Requests for temporary exceptions to this procedure must be submitted in writing to the Head of IT and Cybersecurity Analyst. All exceptions must be logged and risk-assessed.

Enforcement

Failure to follow this procedure may result in restricted access, mandatory retraining, formal disciplinary action, or legal referral in the case of negligence or willful misconduct.

References

External Frameworks:

- ISO 27001: Information Security, Cybersecurity and Privacy Protection — ISMS Requirements
- NIST SP 800-160 Vol. 1 Rev. 1 – Systems Security Engineering: Considerations for a Multidisciplinary Approach in the Engineering of Trustworthy Secure Systems
- NIST SP 800-61: Computer Security Incident Handling Guide
- NIST SP 800-30: Guide for Conducting Risk Assessments
- General Data Protection Regulation (GDPR)
- California Privacy Rights Act (CPRA)
- Health Insurance Portability and Accountability Act (HIPAA)
- Payment Card Industry Data Security Standard (PCI-DSS) v4.0

Internal Documents:

- Acceptable Use Policy – Version 1.0
- Data Classification and Handling Policy – Version 1.0
- User Awareness and Training Procedure – Version 1.0
- Asset Register – Shameless Consulting Ltd. (2025)
- Risk Register – Shameless Consulting Ltd. (2025)